

「전자금융감독규정시행세칙」 신규조문 대비표

1. 전자금융감독규정시행세칙

현행	개정안
제2장 <u>망분리 적용 예외·자체 보안성심의 기준 등</u> <u><신 설></u>	제2장 <u>전자금융거래 안전성 확보 등</u> <u>제2조의2(정보처리시스템 가동기록)</u> <u>규정 제13조제1항제9호에 따라 감</u> <u>독원장이 정하는 사항은 다음 각</u> <u>호와 같다.</u> <u>1. 정보처리시스템에 접속한 일시,</u> <u>접속자 및 접근을 확인할 수 있</u> <u>는 접근기록</u> <u>2. 전산자료를 사용한 일시, 사용</u> <u>자 및 자료의 내용을 확인할 수</u> <u>있는 접근기록</u> <u>3. 정보처리시스템내 전산자료의</u> <u>처리 내용을 확인할 수 있는 사</u> <u>용자 로그인·액세스 로그 등 접</u> <u>근기록</u>
<u>제2조의2(망분리 적용 예외) ① 규정</u> <u>제15조제1항제3호나목에서 금융</u> <u>감독원장의 확인을 받은 경우란</u> <u>다음 각 호와 같다.</u> <u>1.·2. (생략)</u> <u>② 규정 제15조제1항제5호나목에</u>	<u>제2조의3(망분리 적용 예외) ① ---</u> <u>----- 감</u> <u>독원장-----</u> <u>-----.</u> <u>1.·2. (현행과 같음)</u> <u>② -----</u>

서 금융감독원장이 인정하는 경우
란 다음 각 호와 같다.

1. (생략)

2. 업무상 외부통신망과 연결이 불가피한 다음의 정보처리시스템
(다만, 필요한 서비스번호(port)
에 한하여 연결할 수 있다)

가.·나. (생략)

다. 다른 계열사(「금융회사의
정보처리 업무 위탁에 관한
규정」 제2조 제3항의 “계열
사”를 말한다)와 공동으로 사
용하는 정보처리시스템

3.·4. (생략)

③ 제1항 및 제2항의 규정은 금융
회사 또는 전자금융업자가 자체
위험성 평가를 실시한 후 <별표
7>에서 정한 망분리 대체 정보보
호통제를 적용하고 정보보호위원
회가 승인한 경우에 한하여 적용
한다.

제2조의3(클라우드컴퓨팅서비스의
보고) 규정 제14조의2제4항에 따
라 감독원장에게 보고하는 양식은
별지 제6호 서식에 따른다.

<신설>

- 감독원장-----
-----.

1. (현행과 같음)

2. -----

가.·나. (현행과 같음)

다. -----

----- 제2조제3항 -----

3.·4. (현행과 같음)

③ -----

----- 별표 7 -----

-----.

제2조의4(클라우드컴퓨팅서비스의
보고) ① -----
----- 별
지 제6호서식에 따른다.

② 규정 제14조의2제4항 및 제5항
에 따라 감독원장에게 보고할 경

제2조의4(법인 이용자 정보의 사용에 대한 동의) 규정 제13조 제1항 제10호에 따라 동의를 얻는 경우 다음 각 호의 사항을 정보주체에게 사전에 알려야 한다.

1. ~ 4. (생략)

<신설>

우 첨부해야 하는 서류는 다음 각 호와 같다.

1. 「금융회사의 정보처리 업무 위탁에 관한 규정」 제7조제1항 각 호에 관한 서류

2. 규정 제14조의2제1항제1호에 따른 업무의 중요도 평가 기준 및 결과

3. 규정 제14조의2제1항제2호에 따른 클라우드컴퓨팅서비스 제공자의 건전성 및 안전성 등에 대한 평가 결과

4. 규정 제14조의2제1항제3호에 따른 업무 연속성 계획 및 안전성 확보조치에 관한 사항

5. 규정 제14조의2제2항에 따른 정보보호위원회 심의·의결 결과

6. 규정 별표 2의5의 계약서 주요 기재사항을 포함한 클라우드컴퓨팅서비스 이용계약서

제2조의5(법인 이용자 정보의 사용에 대한 동의) --- 제13조제1항제8호-----

-----.

1. ~ 4. (현행과 같음)

제2조의6(정보보호시스템 운영) 규

<신 설>

정제15조제2항에 따라 감독원장이 정하는 사항은 다음 각 호와 같다.

1. 최소한의 서비스번호(port)와 기능만을 적용하고 업무목적 이외의 기능 및 프로그램을 제거할 것

2. 보안정책의 승인, 적용, 등록, 변경 및 삭제에 대해 기록·보관하고 적용된 보안정책의 적정성을 주기적으로 점검할 것

3. 정보보호시스템 원격관리를 금지할 것. 다만, 원격관리가 불가피한 경우 전용회선(전용회선과 동등한 보안수준을 갖춘 가상의 전용회선을 포함한다) 사용, 접근 통제 등을 포함한 원격 접속 보안 대책을 수립·운용할 것

4. 정보보호시스템의 정상 작동 여부 확인을 위하여 시스템 상태의 감시, 경고가 가능하도록 모니터링시스템을 갖추고 시스템 장애, 가동중지 등 긴급사태에 대비하여 백업 및 복구 절차 등을 수립·운용할 것

제2조의7(프로그램 통제) 규정 제29조에 따라 감독원장이 정하는 사항은 다음 각 호와 같다.

1. 적용대상 프로그램 종류 및 등록·변경·폐기 방법을 마련할 것
2. 프로그램 변경 전후 내용을 기록·관리할 것
3. 프로그램 등록·변경·폐기내용의 정당성에 대해 제3자의 검증을 받을 것
4. 변경 필요시 해당 프로그램을 개발 또는 테스트 시스템으로 복사 후 수정할 것
5. 프로그램에 대한 접근은 업무담당자에 한정하고, 적절한 접근권한(읽기·쓰기·실행 등 포함) 설정 및 중요 조작에 대한 책임자 사전승인 등 통제절차를 수립·운용할 것
6. 프로그램 반출, 실행프로그램의 생성 및 운영시스템 적용은 해당 프로그램 담당자 이외의 자가 수행할 것
7. 운영시스템 적용은 처리하는 정보의 기밀성·무결성·가용성 및 전자금융거래의 안전성과 신뢰성이 훼손되지 않도록 충분한 테스트 및 관련 책임자 승인 후 실시할 것

- 8. 운영체제, 데이터베이스관리프
로그램 등의 시스템 프로그램도
응용프로그램과 동일한 수준으로
관리할 것
- 9. 프로그램 설명서, 프로그램 목
록 및 사용자·운영자 지침서 등
프로그램 유지보수에 필요한 문
서를 작성·관리할 것
- 10. 전자금융거래에 사용되는 프
로그램은 도입·분석·설계 단
계에서부터 안전성과 신뢰성을
확보할 수 있는 대책을 마련하고,
운영시스템 적용 전에 동 대책이
반영되었는지 충분히 검증하고
적용할 것

제3조(자체 보안성심의 기준 등) ①
 규정 제36조제1항에 따른 금융감
독원장이 정하는 기준과 절차란
 다음 각 호를 말한다.

1. 정보통신망을 이용하여 신규전
 자금융업무를 수행하는 경우
<별표 1>의 기준에 따라 보안성
 심의를 실시한 후 정보보호최고
 책임자의 승인을 받을 것
2. 공동으로 전자금융거래 관련 표
 준을 제정하는 경우 <별표 1의
2>의 기준에 따라 보안성심의를

제3조(자체 보안성심의 기준 등) ①
 ----- 감독원장

 -----.

1. -----
 ----- 별
표 1-----

2. -----
 ----- 별표 1의2-----

실시할 것(다만, 이 경우 특정 금융회사 또는 전자금융업자가 다른 금융회사등을 대표하여 규정 제36조제2항에 따른 자체 보안성심의 결과보고서를 제출할 수 있음).

② 금융회사 또는 전자금융업자가 규정 제36조제2항에 따라 제출하는 자체 보안성심의 결과보고서의 양식은 제1항제1호의 경우 별지 제3호 서식에, 제1항제2호의 경우 별지 제4호 서식에 각각 따른다.

③ 금융회사 또는 전자금융업자는 제1항에 따른 자체 보안성심의를 수행함에 있어 필요한 경우 규정 제37조의4제1항의 침해사고대응기관, 「정보통신기반보호법」 제16조제1항의 정보공유·분석센터 등 외부기관에 보안대책의 적정성 여부 등에 대한 검토를 의뢰할 수 있다.

④ 규정 제36조 제2항 단서에서 “금융감독원장이 인정하는 기준”이란 다음 각 호에서 정하는 요건을 충족하는 것을 말한다.

1.·2. (생략)

<신설>

-----.

② -----

----- 별지 제3호서식에----- 별지 제4호서식-----.

③ -----

----- 제37조의6-----

-----.

④ -- 제36조제2항 -----

-----.

1.·2. (현행과 같음)

제3조의2(정보기술부문 계획서 제

제7조의3(정보보호최고책임자의 업무) 규정 제37조의5에 따라 감독원장이 정하는 정보보안 점검항목은 별표 3-2와 같다.

제8조(약관의 제정 또는 변경) ① (생략)

② 금융회사 또는 전자금융업자가 제1항에 따라 약관을 제정하거나 변경하는 경우에는 당해 약관과 약관내용을 이해하는 데 필요한 관련서류를 별지 제7호 서식에 따라 감독원장에게 보고한다.

③ (생략)

제8조의3(거래금액 기준 초과시 신고 등) ① 법 제30조제3항제1호에 해당하는 전자금융업자는 분기별 거래 총액(결제대행금액, 결제대금예치금액 또는 전자고지결제금액)이 규정 제42조의2제1항에 따른 거래금액 기준을 초과한 경우 해당 분기 종료 후 45일 이내에 별지 제5호 서식에 따라 감독원장에게 초과 내역 및 자본금 증액 계획을 신고하여야 한다.

출) 규정 제36조의2제1항에 따라 제출하는 정보기술부문계획서의 양식은 별지 제8호 서식에 따른다.

<삭 제>

제8조(약관의 제정 또는 변경) ① (현행과 같음)

② -----

----- 별지 제7호서식 -----
-----.

③ (현행과 같음)

제8조의3(거래금액 기준 초과시 신고 등) ① -----

----- 별지 제5호서식 -----

-----.

② (생 략)

제12조(정보기술부문 사고보고) <신 설>

<신 설>

② (현행과 같음)

제7조의4(정보기술부문 사고보고)

① 규정 제37조의5제4항에 따라 감독원장이 정하는 사고보고 대상은 다음 각 호와 같다.

1. 정보처리시스템 또는 통신회선 등의 장애로 인하여 다음 각 목 중 하나에 해당하는 사고가 발생한 경우

가. 전자금융업무 지연·중단 시간이 30분 이상인 경우

나. 전자금융업무 지연·중단 시간이 10분 이상이고 해당 전자금융서비스 가입자가 1만명 이상인 경우

2. 전산자료 또는 프로그램의 조작 및 오류와 관련된 사고가 발생한 경우

3. 전자적 침해행위로 인해 정보처리시스템에 사고가 발생하거나 이로 인해 이용자가 금전적 피해를 입었다고 금융회사 또는 전자금융업자에게 통지한 경우

4. 법 제9조제1항의 규정에서 정하는 사고가 발생한 경우

② 제1항에도 불구하고 다음 각 호에 해당하는 경우는 사고보고

① 금융회사 및 전자금융업자는 규정 제73조에 따른 정보기술부문 및 전자금융 사고가 발생한 경우 별지 제2호서식 별첨1에 따라 즉시 보고하여야 한다. 다만, 규정 제73조제1항제4호의 사고 중 사고 금액이 3억원 미만인 사고의 경우 매월 발생한 사고를 익월 15일까지 별지 제2호서식 별첨2에 따라 일괄 보고할 수 있다.

② 제1항에 따른 사고보고는 최초 보고, 중간보고 및 종결보고로 구분한다.

1. 최초보고 : 사고를 인지 또는 발

대상에서 제외한다.

1. 제1항제1호에 해당하는 사고 중
영업점 내 장애의 경우 1개 영업
점에 국한된 전자금융업무 중단
· 지연

2. 제1항제1호에 해당하는 사고 중
이용자에게 단순 정보 제공을 위
한 공개용 웹서버 등의 장애 또
는 금융상품 및 서비스와 무관한
장애

3. 법 제9조제1항제1호 또는 제3호
의 사고가 발생하였으나 사고금
액이 100만원 미만인 경우

③ ----- 제1
항의 -----

----- 지체
없이 보고하여야 하며, 정당한 사
유없이 그 사실을 안 때부터 24시
간을 경과하여서는 아니된다. ---
법 제9조제1항제1호-----
-----.

④ 제3항-----

-----.

1. -----

3. 종결보고 : 사고금액에 대한 배상조치가 완료되거나 사고조치 등이 완료되어 정상적인 업무를 수행하게 된 때 제1호의 방법에 따라 보고한다. 다만, 최초보고

3. ----- 사고발생 원인 파악
및 조치, 재발방지 대책 마련 등
이 완료(사고금액에 대한 배상책
임이 있는 경우에는 배상조치까
지 포함)되어 -----

시 조치가 이미 완료된 경우에는 종결보고를 생략할 수 있다. ③ (생 략) ④ 금융회사 및 전자금융업자는 비상연락 담당자가 제3항에 따라 지정되거나 변경된 경우에는 제2 항제1호에서 정한 보고방법에 따 라 감독원장에게 즉시 보고하여야 한다. <신 설>	-----. -----. ⑤ (현행 제3항과 같음) ⑥ ----- ----- 제5항----- ----- 제4항 제1호----- ----- --. ⑦ 감독원장은 제4항에 따라 보고 받은 내용이 제1항제3호의 사고 발생인 경우에는 규정 제37조의6 제1항 각 호에 따른 침해사고대응 기관에도 알려야 한다.
<신 설>	부 칙 <개정 2025.2.5.> 제1조(시행일) 이 세칙은 2025년 2월 5일 부터 시행한다.

2. 전자금융감독규정시행세칙 <별표 3-2>

현 행	개 정 안
<별표 3-2> 정보보안점검항목 <생 략>	<별표 3-2> 삭제

3. 전자금융감독규정시행세칙 별표 <별표 7>

현 행	개 정 안
<별표 7> 망분리 대체 정보보호통제	<별표 7> 망분리 대체 정보보호통제

구분	통제사항	구분	통제사항
공통	(생 략)	공통	(현행과 같음)
메일 시스템	(생 략)	메일 시스템	(현행과 같음)
업무용 단말기	(생 략)	업무용 단말기	(현행과 같음)
<u>연구·개발</u>	○ (생 략) ○ 연구·개발망과 내부망간 독립적인 네트워크 구성 (신 설) ○ (생 략) ○ (생 략) ○ 중요 소스코드 등에 대한 외부 반출방지 등 보안관리 대책 수립·적용	<u>연구·개발</u> ○ (현행과 같음) ○ 연구·개발망과 내부망간 독립적인* 네트워크 구성 * 다만, 연구개발망과 규정 제15조제1항제3호의 내부 업무용시스템간 연결에 한하여 논리적 방식으로 분리 가능 ○ (현행과 같음) ○ (현행과 같음) ○ ----- ----- 및 망간 전송* 허용 등에 따른 ----- * 다만, 연구개발망과 규정 제15조제1항제5호의 전산실간 전송시 개발산출물 등 필수적인 경우에 한함	
원격 접속	(생 략)	원격 접속	(현행과 같음)

4. 전자금융감독규정시행세칙 별지서식

현행	개정안
별지 1-8 정보기술 및 정보보호부문 인력현황 (IT017) 작성양식 (생략) 【작성요령】 1. 전자금융 감독규정 <별표1> '정보기술부문 인력 및 정보보호 인력 기준', '금융회사 정보기술(IT)부문 보호업무' 행정지도에 따른 2. 기준인력: 정보기술의 경우 총 임직원, 정보보호의 경우 정보기술부문 인력을 기재	별지 1-8 정보기술 및 정보보호부문 인력현황 (IT017) 작성양식 (생략) 【작성요령】 1. 총임직원 및 외주인력 가. 총임직원 수는 금융회사등의 상시 종업원 (「소득세법」에 따른 원천징수의무자가 근로소득세를 원천징수한 자를 기준으로 한다. 이하 같다)으로 하되, 1년 이상 장기휴직자와 외주(outsourcing)인력은 제외한다. 나. 외주인력이란 금융회사등과의 외부주문등에 따라 업무를 처리하는 업체에 소속된 자로서 다음 각 호의 기준에 따라 산정한다. (1) 금융회사등의 정보기술부문 업무 수행을 위한 정보화 기획, 전자금융기반시설 운영, 정

보보안 등의 IT(Information Technology, 정보통신기술)업무 종사자를 포함한다.

(2) 전자금융기반시설의 하드웨어 또는 소프트웨어 등의 유지보수를 수행하기 위한 제조사의 상시 운영 기술인력은 포함한다.

(3) 정보시스템 개발 프로젝트를 수행하기 위하여 상주하는 외주업체의 IT업무 종사자는 제외한다.

(4) 외주인력 중 월·주 단위 등 부정기적이거나 일시적인 인력은 제외한다.

(5) 그 밖의 금융위원장이 외주인력에 포함 또는 제외하는 것이 필요하다고 인정한 인력은 해당 인력을 외주인력에 포함시키거나 제외할 수 있다.

2. 정보기술부문 인력

정보기술부문 인력이란 다음 각 목에 해당되는 자를 말한다.

가. 금융회사 등의 총임직원 중 내부 규정에 따라 IT 기획·개발·운영·정보보호 등 정보기술부문의 업무를 처리하는 사람

나. 다음 각 호에 소속되어 IT업무를 담당하는 상시 종업원 중 해당 금융회사등의 IT업무를 적법한 절차에 의해 수행하는 사람으로서, 규정 제60조제1항제13호에 의한 업무수행인력 관리방안에 따라 관리되고 있는 사람(이 경우, 해당 금융회사등의 정보기술 인력 규모는 다음 각 호의 회사 또는 기관이 공동으로 위탁 받은 정보기술부문에 대한 운영비용 분담비율에 따라 산정한다)

(1) 「금융지주회사법」 제2조제1항에 따른 자회사 또는 손자회사로서 금융업을 영위하는 회사에 대한 전산·정보처리 등의 용역을 제공하는 회사

(2) 금융회사등이 지분을 50%를 초과하여 소유하는 IT자회사 또는 IT손자회사로서 당해 금융회사 등에 대한 전산·정보처리 등의 용역 제공을 전업으로 하는 회사

(3) 「독점규제 및 공정거래에 관한 법률」 제2조제11호에 따라 기업집단에 속하는 금융회사들 또는 전자금융업자들이 합하여 지분을 50%를 초과하여 소유하는 IT자회사 또는 IT손자회사로서 당해 금융회사들 또는 전자금융업자들에 대한 전산·정보처리 등의 용역 제공을 전업으로 하는 회사

(4) (주)코스콤, 상호저축은행중앙회, 신용협동조합중앙회, 농협중앙회, 수협중앙회, 산림조합중앙회, 새마을금고중앙회 등과 같이 회원사, 상호저축은행, 신용협동조합, 조합, 지역

금고 등의 전자금융기반시설에 대한 운영을 공동수탁하는 기관

다. 나목을 제외한 외주인력 중 해당 금융회사 등의 IT업무를 적법한 절차에 의해 수행하는 사람으로서, 규정 제60조제1항제13호에 의한 업무수행인력 관리방안에 따라 관리되고 있는 사람 (다만, 다목의 인력은 가목의 인력 규모 내에서 정보기술부문 인력으로 인정한다)

3. 정보보호 인력

정보보호 인력이란 다음 각 목에 해당되는 자를 말한다.

가. 금융회사 등의 총임직원 중 내부 규정에 따라 정보보호 업무를 처리하는 사람

나. 다음 각 호에 소속되어 정보보호 업무를 담당하는 상시 종업원 중 해당 금융회사 등의 정보보호 업무를 적법한 절차에 의해 수행하는 사람으로서, 규정 제60조제1항제13호에 의한 업무수행인력 관리방안에 따라 관리되고 있는 사람(이 경우, 해당 금융회사등의 정보보호 인력 규모는 다음 각 호의 회사 또는 기관이 공동으로 위탁 받은 정보보호 업무에 대한 운영비용 부담비율에 따라 산정한다)

(1) 「금융지주회사법」 제2조제1항에 따른 자회사 또는 손자회사로서 금융업을 영위하는 회사에 대한 전산·정보처리 등의 용역을 제공하는 회사

(2) 금융회사 등이 지분을 50%를 초과하여 소유하는 IT자회사 또는 IT손자회사로서 당해 금융회사 등에 대한 전산·정보처리 등의 용역 제공을 전업으로 하는 회사

(3) 「독점규제 및 공정거래에 관한 법률」 제2조제11호에 따른 기업집단에 속하는 금융회사들 또는 전자금융업자들이 합하여 지분을 50%를 초과하여 소유하는 IT자회사 또는 IT손자회사로서 당해 금융회사들 또는 전자금융업자들에 대한 전산·정보처리 등의 용역 제공을 전업으로 하는 회사

(4) (주)코스콤, 상호저축은행중앙회, 신용협동조합중앙회, 농협중앙회, 수협중앙회, 산림조합중앙회, 새마을금고중앙회 등과 같이 회원사, 상호저축은행, 신용협동조합, 조합, 지역금고 등의 전자금융기반시설에 대한 운영을 공동수탁하는 기관

다. 나목을 제외한 외주인력 중 해당 금융회사 등의 정보보호 업무를 적법한 절차에 의해 수행하는 사람으로서, 규정 제60조제1항제13

별지 1-9 정보기술 및 정보보호부문 예산현황 (IT018)

작성양식 (생략)

【작성요령】

1. 전자금융감독규정 <별표2> '정보기술부문 인력 및 정보보호 예산 기준', '금융회사 정보기술(IT) 부문 보호업무' 행정지도에 따름
2. 편성액은 최초 최고정보책임자(CIO)와 정보보호 최고책임자(CISO)가 승인한 금액을 기재
3. 집행액은 보고서를 작성하는 기준분기를 기준으로 누적된 금액을 기재

호에 의한 업무수행인력 관리방안에 따라 관리되고 있는 사람(다만, 다목의 인력은 가목의 인력 규모 내에서 정보보호 인력으로 인정한다)

4. 기준인력: 정보기술의 경우 총임직원, 정보보호의 경우 정보기술부문 인력을 기재

별지 1-9 정보기술 및 정보보호부문 예산현황 (IT018)

작성양식 (생략)

【작성요령】

1. 정보기술부문 예산 기준

가. 정보기술부문 예산 개요

- (1) 정보기술부문과 관련하여 기획·개발·운영·유지·보수 및 정보보호 등에 소요되는 모든 경비의 합계
- (2) 정보기술부문 예산은 건물·시설 이용료, 건물·시설 공사비, 전기·전화 등 각종 세금과 공과금 및 사업성 경비는 제외

나. 정보기술부문 예산 항목

예산 항목	세부 내용
(1) 인건비	○ 정보기술부문과 관련하여 기획·개발·운영·유지·보수를 수행하는 내부 인력(정규직 및 계약직 포함)의 인건비 및 복리 후생비 등 관련 경비 일체 ○ 개인사무자동화기기(PC 등) 및 정보처리시스템을 단순 조화·이용하는 내부직원과 외부 주문·제휴에 따라 정보기술부문 관련 업무를 수행하는 외부 인력은 제외
(2) 정보처리시스템 구입비 및 임차료	○ 정보기술부문과 관련하여 하드웨어 및 소프트웨어를 구입 또는 임차(리스)하는데 소요되는 경비 일체 ○ 단순히 사무를 처리하기 위하여 사용하는 사무자동화기기(PC, 프린터, 팩스 등)는 제외
(3) 정보처리시스템 유지보수비	○ 정보처리시스템의 성능을 최적화하고 정상적 기능을 수행할 수 있도록 정기 또는 수시로 정보처리시스템을 유지하고 관리하는데 소요되는 경비 일체 ○ 정보처리시스템 관련 소모품 교체 비용 포함
(4) 정보기술서비스 이용료	○ 정보처리시스템 및 정보기술부문과 관련하여 필요한 서비스를 이용하는데

예산 항목	세부 내용
	소요되는 경비 일체 ○ S/W라이선스비용, 기술이전·이용료, 정보이용료, 특허 사용료, 정보보호관제·인증·재해복구 등 정보보호서비스 이용료 포함
(5) 정보기술 외주 용역비	○ 외부 주문 또는 제휴 등에 따라 정보처리시스템과 관련하여 기획·개발·운영·유지·보수의 일부 또는 전부의 업무를 외부업체에 위탁(아웃소싱)하여 수행하는데 소요되는 경비 일체
(6) 정보 기술 컨설팅 비용	○ 정보처리시스템 및 정보기술부문과 관련하여 외부기관으로부터 자문, 점검, 분석, 평가, 인증, 심사, 연구, 조사에 소요되는 경비 일체 ○ 감리비, 자문료, 취약점 분석·평가 비용, 품질인증심사비, 국제표준인증심사비 포함
(7) 정보 기술 교육·훈련비	○ 정보처리시스템 및 정보기술부문과 관련하여 임직원의 교육, 직무훈련·연수 및 회의·행사에 소요되는 경비 일체 ○ 도서·교재 구입비, 교육자료인쇄비, 인쇄비, 세미나·워크샵·학술발표회 등 회의·행사개최·참가비, 강사료, 직무교육프로그램참가비·수강료, 직무훈련·연수과정(대학포함) 수업료 포함
(8) 통신회선 이용료	○ 정보처리시스템과 관련하여 정보의 송신, 수신과 정보처리시스템간 접속·연계를 위하여 정보통신사업자(인터넷 서비스제공자 포함)로부터 인터넷, 전용회선 등 통신회선을 이용하는데 소요되는 경비 일체 ○ 재해복구센터용 통신회선 이용료, 디도스공격대응용 통신회선 이용료 포함 ○ 직원의 정보검색, 이메일 송·수신 등 사무자동화용으로 사용하는 통신회선의 이용료는 제외

※ 상기 정보기술부문 예산 항목 이외에 규정 제2조 제4호에서 정한 정보기술부문과 관련된 예산 항목을 포함할 수 있다.

2. 정보보호 예산 기준

가. 예산 개요

정보기술부문 예산 중 정보보호와 관련하여 소요되는 모든 경비의 합계. 다만, 정보기술부문 예산에 포함되지 아니한 경비는 제외한다.

나. 예산 항목

예산 항목	세부 내용
(1) 정보보호 관련 인건비	○ 정보보호와 관련하여 기획·개발·운영·유지·보수를 수행하는 내부 인력(정규직 및 계약직 포함)의 인건비 및 복리후생비 등 관련 경비 일체 ○ 외부 주문·제휴에 따라 정보보호 관련 업무를 수행하는 외주 인력과 관련된 경비는 제외
(2) 정보보호시스템 구입비 및 임차료	○ 정보보호와 관련하여 하드웨어 및 소프트웨어를 구입 또는 임차(리스)하는데 소요되는 경비 일체 ※ 다. 정보보호시스템 분류표 참고
(3) 정보보호시스템 유지보수비	○ 정보보호시스템의 성능을 최적화하고 정상적 기능을 수행할 수 있도록 정기 또는 수시로 정보보호시스템을 유지하고 관리하는데 소요되는 경비 일체 ○ 정보보호시스템 관련 소모품 교체 비용 포함
(4) 정보보호서비스 이용료	○ 정보보호와 관련하여 제공되는 서비스를 이용하거나 정보보호시스템과 관련하여 필요한 기술을 확보하는데 소요되는 경비 일체 ※ 라. 정보보호서비스 분류표 참고 ○ 정보보호S/W라이선스비용, 정보보호기술이전·이용료 포함
(5) 정보보호 관련 외주 용역비	○ 외부 주문 또는 제휴에 따라 정보보호시스템과 정보보호서비스와 관련하여 기획·개발·운영·유지·보수의 일부 또는 전부의 업무를 외부업체에 위탁(아웃소싱)하는데 소요되는 경비 일체
(6) 정보보호 관련 컨설팅 비용	○ 정보보호와 관련하여 외부기관으로부터 자문, 점검, 분석, 평가, 인증, 심사, 연구, 조사에 소요되는 경비 일체 ※마. 정보보호컨설팅 분류표 참고
(7) 정보보호 관련 교육·훈련비	○ 정보보호와 관련하여 임직원의 교육, 직무훈련·연수 및 회의·행사에 소요되는 경비 일체
(8) 정보보호 관련 통신회선 이용료	○ 재해복구센터용 통신회선 이용료 ○ 디도스공격대응용 통신회선 이용료

※ 상기 정보보호 예산 항목이외 전자금융감독규정 제2조 제5호의 규정에서 정한 정보보호와 관련된 예산 항목을 포함할 수 있다.

다. 정보보호시스템 분류표

대분류	소분류	세부항목
-----	-----	------

대분류	소분류	세부항목
(1) 콘텐츠 정보보호	① DB정보보호	○ DB암호화 ○ DB접근통제
	② 디지털저작권관리	○ 저작권관리(DRM) ○ 자료유출방지(DLP)
	③ 개인정보보호	○ 정보보호서버 ○ 개인정보필터링 S/W
	④ 데이터백업	○ 데이터 백업·소산시스템 ○ 재해복구(DR)시스템
	⑤ 기타	○ 도청 및 감청 방지 제품
(2) 시스템 정보보호	① 사용자 인증	○ 정보보호토큰(HSM) ○ 정보보호스마트카드 ○ 일회용 비밀번호(OTP) 생성시스템 ○ 생체(Bio)인식시스템
	② PC정보보호	○ PC정보보호관리 ○ 정보보호USB ○ 키보드해킹방지프로그램
	③ Anti-Virus/Spam	○ 바이러스백신(Vaccine) ○ 바이러스월(wall) ○ 안티스파이웨어 ○ 스팸(Spam) 차단 ○ 피싱(Phishing) 방지
	④ 접근통제	○ 정보보호운영체제(SecureOS) ○ 통합접근권한관리(EAM) ○ 싱글사인온(SSO) ○ 통합계정관리시스템(IM/IAM)
(3) 네트워크 정보보호	① 침입차단시스템	○ 네트워크방화벽 ○ 시스템 방화벽 ○ PC방화벽 ○ 웹방화벽 ○ 통합위협관리시스템(UTM)
	② 침입방지시스템	○ 침입탐지(IDS) ○ 침입방지(IPS)
	③ 가상사설망	○ VPN
	④ 전자서명	○ 공개키기반(PKI)

대분류	소분류	세부항목
	⑤ 네트워크통제	○ 망 접근 제어(NAC)
	⑥ 무선·모바일정보보호	○ 무선랜정보보호 ○ 모바일정보보호
	⑦ DDoS대응	○ DDoS대응(탐지, 차단)시스템
(4) 정보보호 관리	① 정보보호관리 서비스	○ 네트워크정보보호관리(NMS) ○ 위협관리시스템(TMS) ○ 위협관리시스템(RMS) ○ 기업정보보호관리(ESM) ○ 패치관리시스템(PMS) ○ 로그(log) 관리·분석 툴 ○ 취약점 분석·포렌식 툴

※ 상기 정보보호 예산 항목 이외에 규정 제2조제5호에서 정한 정보보호와 관련된 예산 항목을 포함할 수 있다.

라. 정보보호서비스 분류표

대분류	소분류	세부항목
정 보 보 호 서비스	① 인증서비스	○ 공인/시설인증서비스
	② 정보보호관제 서비스	○ 정보보호관제서비스
	③ 재해복구 서비스	○ 재해복구서비스
	④ 위협정보제공 서비스	○ 취약점, 대응방안 등 정보제공서비스

※ 상기 정보보호서비스 이외에 규정 제2조제5호의 규정에서 정한 정보보호와 관련된 서비스를 포함할 수 있다.

마. 정보보호컨설팅 분류표

별지 제2호 서식

대분류	소분류	세부항목
정 보 보 호 컨설팅	① 정 보 보 호 컨설팅	○ 정보보호계획 수립·자문 ○ 정보보호표준 인증 심사 ○ 정보보호제품 시험·평가 ○ 정보보호 연구·개발 ○ 정보기술부문 감리
	② 취약점분석	○ 취약점 분석·평가 ○ 모의 해킹 ○ 모의 훈련

※ 상기 정보보호컨설팅 이외에 규정 제2조제5호에서
정한 정보보호와 관련된 컨설팅을 포함할 수 있다.

4. 편성액은 최초 최고정보책임자(CIO)와 정보보호
최고책임자(CISO)가 승인한 금액을 기재

5. 집행액은 보고서를 작성하는 기준분기를 기준으로
누적된 금액을 기재

별지 제2호 서식

작 성 자 :	(직 위)
전화번호 :	

정보기술부문 및 전자금융 사고보고서

문서번호 20 . . .

수 신

참 조

제 목 정보기술부문 및 전자금융 사고보고
전자금융감독규정 제73조에 따라
붙임과 같이 사고를 보고합니다.

붙 임 사고내용 1부. 끝.

○ ○ 금융회사 사장 (인)

<별첨1> 정보기술부문 및 전자금융 사고내용
<별첨2> 일괄보고서

작 성 자 :	(직 위)
전화번호 :	

정보기술부문 및 전자금융 사고보고서

문서번호 20 . . .

수 신

참 조

제 목 정보기술부문 및 전자금융 사고보고
전자금융감독규정 제37조의5에 따라
붙임과 같이 사고를 보고합니다.

붙 임 사고내용 1부. 끝.

○ ○ 금융회사 대표이사 (인)

<별첨1> 정보기술부문 및 전자금융 사고내용
<별첨2> 일괄보고서

※ 별첨1, 별첨2 개정사항은 [별첨] 참조

<신 설>

별지 제8호 서식

작 성 자 : (직 위)

확 인 자 : (직 위)

‘00년도 정보기술부문 연간 계획서

문서번호 20 . . .

수 신

참 조

제 목 ‘00년도 정보기술부문 연간 계획서
제출

전자금융거래법 제21조 제4항에 따라
붙임과 같이 ‘00년도 정보기술부문 연간 계획서를
제출합니다.

붙 임 ‘00년도 정보기술부문 연간 계획서
1부. 끝.

‘ 〇 〇 〇 〇 대표이사 (인)

(붙임)

000년도 정보기술부문 연간 계획서

1. 개요

☐ 제출일 : ‘00년 0월 0일

※ 매 사업연도 초일부터 3개월 이내에 정보기술부문에 대한
계획 제출 필요

☐ 대상 기간 : ‘00년 0월 0일 ~ ‘00년 0월 0일

※ [참고] 사업연도 결산월 : 0월

☐ 정보보호심의위원회 심의의결일 : 0000년 0월 0일

2. 정보기술부문의 추진목표 및 추진전략

□ 추진 목표

※ 추진 목표를 상세하기 기술

□ 추진 전략

※ 추진 전략을 상세하기 기술

3. 'OO년도(직전 연도) 추진 실적

구분	프로젝트명	수행 기간	상세 추진 내용	이행 여부
정보 기술		'OO년 O월~O월		완료
정보 보안				

※ 미완료의 경우 사유를 상세 추진내용에 함께 작성할 것

4. 'OO년도 정보기술부문 추진 계획

구분	프로젝트명	수행 기간	세부실행계획	비고
정보 기술		'OO년 O월~O월		
정보 보안				

5. 정보기술부문 조직 구성 및 인력 현황

□ 정보기술부문 조직 구성도

※ 정보기술부문 조직현황(조직도 포함)하고 CIO, CISO 및 겸직 여부 등 조직관련 규정 준수 여부 표기할 것 (회사 자산, 인력 등 근거 표기)

□ 정보기술부문 인력 현황

(‘OO년 O월 O일 기준, 단위: 명, %)

총 임직원수	정보기술부문		정보보호부문	
	인력수	비율	인력수	비율
OOO명	OO명 정규직 : OO명 계약직 : OO 명 외주인력 : OO명	0.0%	OO명 정규직 : OO명 계약직 : OO 명 외주인력 : OO명	0.0 %

6. 정보기술부문의 직전 및 당해 연도 예산

구분	직전 연도 집행액	당해 연도 예산편성액
총 예산		
정보기술관련 예산		
정보기술관련 인건비		

구분	직전 연도 집행액	당해 연도 예산편성액
정보처리시스템 구입비 및 임차료		
정보처리시스템 유지보수비		
정보기술서비스 이용료		
정보기술 외주 용역비		
정보기술 컨설팅 비용		
정보기술 교육, 훈련비		
통신회선 이용료		
정보보안관련 예산		
정보보호관련 인건비		
정보보호시스템 구입비 및 임차료		
정보보호시스템 유지보수비		
정보보호서비스 이용료		
정보보호 외주 용역비		
정보보호 컨설팅 비용		
정보보호 교육, 훈련비		
정보보호 관련 통신회선 이용료		

※ 첨부문서
정보보호위원회 심의의결서 사본

[별첨] 시행세칙 별지 제2호 별첨1, 2 개정안

<별첨1> 정보기술부문 및 전자금융 사고내용(현행)

보고형태	☐ 최초 ☐ 중간 ☐ 종결					
사고유형	IT보안사고		정보기술장애		전자금융사기사고	
	☐ 전산자료/프로그램조작 ☐ 정보유출사고 ☐ 내부망 해킹 ☐ 시스템 위변조 ☐ DDoS 공격 ☐ 원인미정(파악중)		☐ 천재지변에 의한 장애 ☐ 시스템/설비 장애 ☐ 프로그램 오류 ☐ 인적 재해 ☐ 외부요인으로 인한 장애 ☐ 원인미정(파악중)		☐ 피싱/파밍(인터넷) ☐ 피싱/파밍(모바일) ☐ 피싱/파밍(텔레뱅킹) ☐ 전자상거래 위변조 ☐ 매체위변조 ☐ 신종 전자금융사기사고 ☐ 계약체결/거래지시 전송·처리 사고 ☐ 원인미정(파악중)	
최초 인지	☐ 금융회사 ☐ 고객(민원인) ☐ 기타: ()					
사고인지일시						
발생일시 및 지속시간						
발생 장소						
피해자 정보 및 피해금액	피해자 성명		생년월일		피해금액	
배상금액			배상인원수			
사고내용						
사고원인						
파급영향						
처리결과						
대 책						

<선택 입력사항> 금융회사 공격자의 정보 제공

공격 유형	☐ DDoS ☐ 파밍악성코드 ☐ C&C서버 ☐ 기타
공격방법	
공격자IP	
공격자 MAC	
Domain정보	
상세내용	

<별첨1> 정보기술부문 및 전자금융 사고내용 (개정안)

보고형태	☐ 최초 ☐ 중간 ☐ 종결						
사고유형	침해사고		전산장애사고		전자금융사기사고		
	1. 공격 대상 ☐ 내부망 시스템 ☐ DMZ구간 시스템 ☐ 기타 ☐ 미상(파악 중)		☐ 업무처리 프로그램 오류 - 로직 오류 - 데이터 오류 ☐ 시스템 장애 - 서버, 네트워크 장비, 스토리지 장비, 보안장비 등 - OS, DBMS, 미들웨어, 네트워크, 보안, WAS 등 ☐ 시설·설비 장애 - 전원공급 차단, 통신회선 훼손 등 ☐ 외부요인으로 인한 장애 - 클라우드 업체, 통신업체, 제휴업체 등 ☐ 미정(파악 중)		☐ 피싱/파밍(인터넷) ☐ 피싱/파밍(모바일) ☐ 피싱/파밍(텔레뱅킹) ☐ 전자상거래/매체 위변조 ☐ 신종 전자금융사기사고 ☐ 원인미정(파악 중)		
	2. 공격 방법 ☐ 악성코드(웬슬, 랜섬웨어, 바이러스 등) ☐ 서비스거부공격 ☐ 보안 취약점 해킹 ☐ 무단 접속 및 조작 ☐ 공급망 보안 침해(연계기관 해킹 등) ☐ 기타 ☐ 미상(파악 중)						
	3. 공격에 따른 피해 ☐ 시스템 및 서비스 중단 ☐ 정보유출 ☐ 중요정보 조작 ☐ 금전적 손실 ☐ 기타 ☐ 미상(파악 중)						
	최초 인지		☐ 금융회사 ☐ 고객(민원인) ☐ 기타: ()				
	사고인지일시						
	사고발생일시						
	사고종료일시						
피해자 정보 및 피해금액	피해자 성명		생년월일		피해금액		
배상금액			배상인원수				
사고금액			사고 영향 이용자수				
사고발생 업무(시스템)명							
사고내용 (현상 및 결과)							
사고원인 (변경시점 및 사유 등)							
파급영향 (영향받은 금융회사 등)							
(외부요인으로 인한 장애) 사고 원인 회사명							
처리결과							
대 책							

<선택 입력사항> 금융회사 공격자의 정보 제공

공격 유형	☐ DDoS ☐ 파밍악성코드 ☐ C&C서버 ☐ 기타
공격방법	
공격자IP	
공격자 MAC	
Domain정보	
상세내용	

<별첨2> 일괄보고서(현행)

보고연월	OO년 OO월		
보고형태	☐ 최초		
사고유형	전자금융사기사고		
전체피해금액		전체피해인원수	
피해자별 사고내역	피해자명		
	세부 사고유형	☐ 피싱/파밍(인터넷) ☐ 피싱/파밍(모바일) ☐ 피싱/파밍(텔레뱅킹) ☐ 전자상거래 위변조 ☐ 매체위변조 ☐ 신종 전자금융사기사고 ☐ 계약체결/거래지시 전송·처리 사고 ☐ 원인미정(파악중)	
	최초인지	☐ 금융회사 ☐ 고객(민원인) ☐ 기타: ()	
	사고인지일시		
	발생일지		
	종료일시		
	지속시간		
	발생장소		
	피해금액		
	배상금액		
	사고내용		
	사고원인		
	파급영향		
	처리결과		
	대 책		

<별첨2> 일괄보고서(개정안)

보고연월	OO년 OO월						
보고형태	☐ 최초						
사고유형	전자금융사기사고						
전체피해금액			전체피해인원수				
피해자별 사고내역	피해자 정보 및 피해금액	피해자 성명		생년월일		피해금액	
	세부 사고유형	☐ 피싱/파밍(인터넷) ☐ 피싱/파밍(모바일) ☐ 피싱/파밍(텔레뱅킹) ☐ 전자상거래/매체 위변조 ☐ 신종 전자금융사기사고 ☐ 원인미정(파악 중)					
	최초인지	☐ 금융회사 ☐ 고객(민원인) ☐ 기타: ()					
	사고인지일시						
	사고발생일시						
	사고종료일시						
	배상금액						
	사고내용						
	사고원인						
	파급영향						
	처리결과						
	대 책						